SMART INDIA HACKATHON 2026

PRAMAAN

Secure Evidence Vault

Problem Statement ID — SIH26190

Problem Statement Title — Secure Digital Document Management

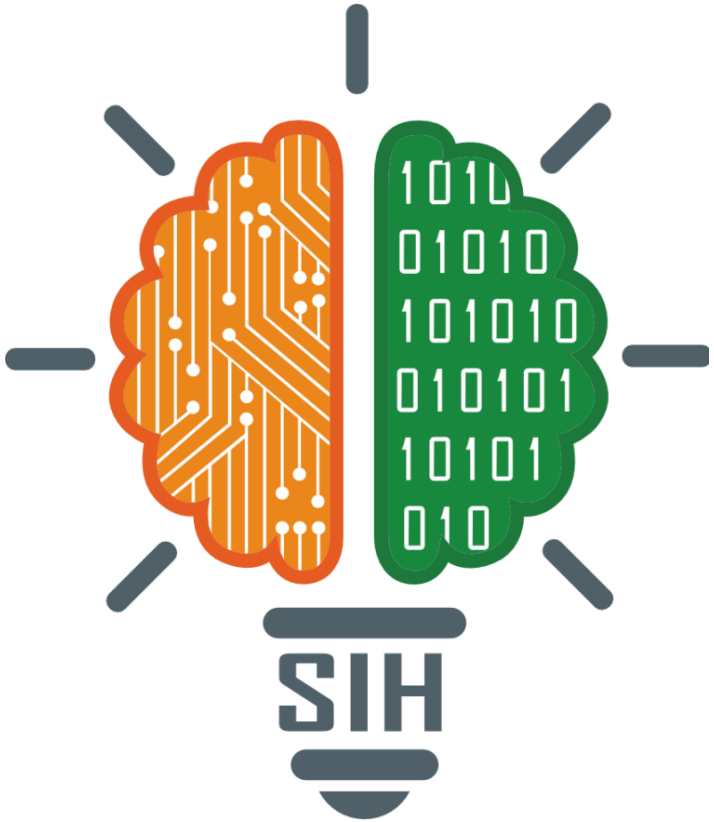
System for law enforcement agencies, courts and investigative departments

Theme — Cybersecurity and Blockchain

PS Category — Software

Team ID — SIH-UPES-2026-T250

Team Name (Registered on portal) — leet



Organisation: Ministry of Home Affairs · National Crime Records Bureau (NCRB)

Separate the trust. Verify before release. Record every access.

Standalone, fully on-premise · no dependency on any external system

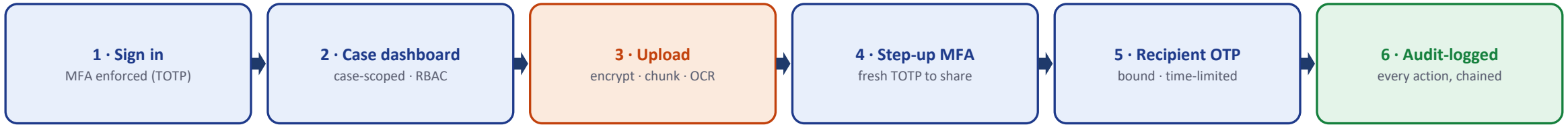
leet

IDEA / SOLUTION

SMART INDIA HACKATHON 2026

Proposed Solution (Idea / Prototype) | How it addresses the problem | Innovation and uniqueness

THE EVIDENCE LIFECYCLE — how a document moves through PRAMAAN, end to end



PROPOSED SOLUTION

- **Encrypted evidence vault.** Replaces the station paper register + shared drive with one indexed, access-controlled case file.
- **Chunked at rest.** Every exhibit is split into 1 MB chunks, each encrypted under its own key — no file ever sits whole on disk.
- **Split-trust storage.** Metadata, ciphertext and keys live on three separate domains; no single machine can rebuild a document.
- **Verify-before-release.** Integrity is re-checked on every download; a tampered exhibit yields 0 bytes.
- **Offline OCR + search.** Tesseract indexes scans in six Indian languages — findable without leaving the network.

HOW IT ADDRESSES THE PROBLEM

- **Proves integrity.** SHA-256 per chunk + one document hash + GCM auth tags detect any alteration before serving.
- **Least-privilege access.** Six roles, re-checked per request; case-scoped resources return 404, never confirming existence.
- **Controlled sharing.** Court/prosecutor exhibits go out only via step-up-verified, recipient-bound, expiring links.
- **Tamper-evident trail.** A hash-chained audit log records actor · action · case · document · result for every event.
- **No plaintext leak surface.** Browser holds no keys; app server stores no bytes; DBA sees only metadata.

INNOVATION & UNIQUENESS

- **Per-chunk derived keys.** HKDF + fresh 96-bit IV per chunk — one key never covers two chunks.
- **Split-trust + mirrors.** Opaque keys on B, hashes on A, keys in KMS; A & B mirrored for HA.
- **Integrity gate.** All checks pass → stream; any fail → 422, 0 bytes, logged.
- **Version control.** Re-uploads create immutable versions; prior versions retained & verifiable.
- **Running prototype.** Real, built and demoable today — not slideware.

Every evidence action is authenticated, integrity-verified and audit-logged.

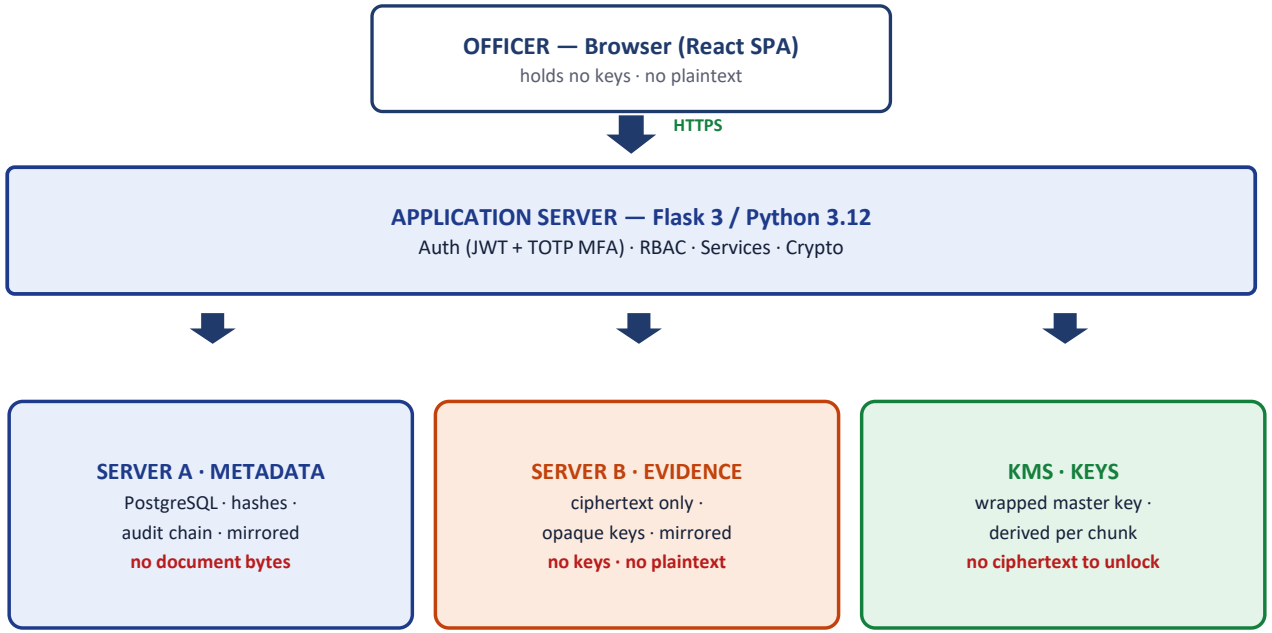
leet

TECHNICAL APPROACH

SMART INDIA HACKATHON 2026

Architecture & trust boundaries | Technologies used (1 of 2)

SPLIT-TRUST ARCHITECTURE — no single domain can reconstruct a document



Breach any ONE domain → nothing readable. Reconstructing a document needs Server A + Server B + KMS, together.

ARCHITECTURE

- **Split trust.** Metadata (A), ciphertext (B) and keys (KMS) on three separate domains.
- **Chunked crypto.** Each 1 MB chunk gets an HKDF key + fresh 96-bit IV under AES-256-GCM.
- **Integrity gate.** SHA-256 per chunk + one document hash + GCM tags, verified before any byte is served.
- **Least privilege.** RBAC re-checked per request; step-up MFA on sensitive actions.
- **Resilience.** Server A & B mirrored (hot-standby); append-only version history.

COMPONENTS

- **Application Server** — Flask 3 / Python 3.12: auth, RBAC, services, crypto.
- **Server A — PostgreSQL 16** metadata, chunk order, hashes, search index, audit chain.
- **Server B — chunk store** AES-GCM ciphertext objects with opaque filenames.
- **KMS — key material** one wrapped master key per document; chunk keys derived on use.
- **OCR — Tesseract** offline, six Indian languages.

TECHNOLOGY STACK React 18 · Vite · TS · Tailwind | Flask 3 · Python 3.12 · SQLAlchemy · JWT · marshmallow | PostgreSQL 16 | AES-256-GCM · HKDF-SHA256 · SHA-256 · Ed25519 · bcrypt · TOTP (pyca/cryptography) | Tesseract OCR ×6 langs | production: MinIO · Vault · Redis · Celery · Nginx (TLS)

leet

TECHNICAL APPROACH

SMART INDIA HACKATHON 2026

Methodology — chunked encryption · integrity verification · tamper-evident audit (2 of 2)

1. CHUNKED ENCRYPTION — every exhibit is split and locked chunk by chunk

THE EXHIBIT
up to 500 MB

→

SPLIT INTO 1 MB CHUNKS
c0 c1 c2 c3

→

PER-CHUNK KEY → AES-256-GCM
chunk_key = HKDF(master_key, doc_id, i)
fresh 96-bit IV · chunk_hash = SHA-256(ciphertext)

→
- → **Server B** ciphertext object (opaque key)
- → **Server A** chunk index · IV · chunk_hash
- → **KMS** wrapped master key

document_hash = SHA-256($chunk_0$_hash || $chunk_1$_hash || … || $chunk_n$_hash) — one fingerprint for the whole exhibit

2. VERIFY BEFORE RELEASE — nothing is streamed until every check passes

Download
request

→

Fetch key
+ all chunks (ordered)

→

VERIFY ALL
SHA-256 == chunk_hash · GCM tag · document_hash

→

All pass?

- → **RELEASE** decrypt · stream in order · log DOWNLOADED
- → **BLOCK** HTTP 422 · 0 bytes · log INTEGRITY_VIOLATION

3. TAMPER-EVIDENT AUDIT — every action hash-chained to the previous one

Event 1 · Genesis
prev = 000…0
this_hash = SHA-256(prev || payload)

→

Event 2
prev = $hash_1$
this_hash = SHA-256(prev || payload)

→

Event 3
prev = $hash_2$
this_hash = SHA-256(prev || payload)

→

… Event n
prev = $hash_{n-1}$
this_hash = SHA-256(prev || payload)

/audit/verify
recomputes the chain
→
names first_break_at

Modify, delete or insert any record → every later hash breaks; verification names the first broken event. (tamper-evident, not immutable)

VERSION CONTROL re-uploads create new immutable versions — prior versions retained & independently verifiable.

MIRROR SERVERS Server A & Server B replicate to hot-standby mirrors for redundancy & availability.

leet

FEASIBILITY AND VIABILITY

SMART INDIA HACKATHON 2026

Feasibility of the idea | Potential challenges & risks | Strategies for overcoming these challenges

FEASIBILITY — technical, operational & financial, proven in a working prototype

TECHNICAL

- **Open-source stack.** React · Flask · PostgreSQL · Tesseract on commodity hardware.
- **Audited crypto only.** pyca/cryptography — nothing hand-rolled.
- **Working prototype.** Every screen is live and demoable today.
- **Tested paths.** Crypto & auth flows covered by tests.

OPERATIONAL

- **Standalone / on-prem.** No external dependency to deploy.
- **Role-based day one.** Six roles, one console, every change logged.
- **Clear prod path.** Vault, MinIO, Redis are drop-in swaps.
- **Low footprint.** One backend, one frontend, Postgres.

FINANCIAL

- **Zero licensing.** Every component open source.
- **No mandatory cloud.** On-premise by default.
- **No crypto-audit cost.** Audited libraries used.
- **Commodity hardware.** No specialised budget required.

SECURITY POSTURE · CHALLENGES → STRATEGY · ROADMAP TO DEPLOYMENT

DEFENDED IN THE PROTOTYPE

- Compromise of the metadata server alone
- Compromise of the chunk store alone
- A DBA reading evidence content
- Stolen credentials without the 2nd factor
- Cross-case / unauthorised API access
- Modification of stored ciphertext
- Retroactive edits to the audit trail

CHALLENGES → STRATEGY

- **Key compromise →** wrapped & isolated in KMS; Vault + rotation in prod.
- **App-server breach →** least-privilege services · step-up MFA · full audit.
- **Stolen live session →** short token TTL · step-up before sensitive actions.
- **Large exhibits →** 1 MB chunk streaming · RAM-safe two-pass in prod.
- **Availability →** mirrored Server A / B · backup & HA on the roadmap.

FUTURE SCOPE / ROADMAP

- Security hardening & penetration testing
- Production KMS + object storage (Vault · MinIO)
- PKI / certified e-signatures
- Backup & high availability (mirror servers)
- Controlled pilot deployment
- Evidence versioning · AI-assisted retrieval

PRAMAAN does not claim compromise is impossible — it limits the blast radius of partial compromise and refuses to release evidence it cannot verify.

leet

IMPACT AND BENEFITS

SMART INDIA HACKATHON 2026

Potential impact on the target audience | Benefits of the solution (social, economic, environmental, etc.)

IMPACT

- **Tamper-evident custody:** an altered chunk is caught before evidence is released.
- **Contained breach:** no single server yields a readable document.
- **Provable accountability:** every access sits on a hash-chained audit trail.
- **One vault, not many:** replaces station registers and shared drives.

BENEFITS

- **Social:** a stronger basis for public trust in how evidence is handled.
- **Economic:** open-source stack, no licence fees, commodity hardware, no GPU.
- **Operational:** standalone and on-premise; OCR search across Indic scripts.
- **Security:** MFA, six-role RBAC, step-up verification and time-limited sharing.

FOR INSTANCE: USER STORY

Scenario A state police cyber cell holds a seized-device extract for a fraud case. It must reach the prosecutor, and the defence later asks whether the file was altered.

1. **Custodian uploads the exhibit**
   MFA sign-in; the file is chunked, encrypted, hashed and OCR-indexed on-premise.
2. **A stored chunk is tampered with**
   Verification fails on retrieval: HTTP 422, 0 bytes served, violation recorded.
3. **Exhibit is shared with the prosecutor**
   Step-up MFA, recipient-bound, time-limited; the recipient opens it via OTP.
4. **Auditor checks the record**
   Recomputes the audit chain; verification names the first event that fails.

Impact
Corrupted evidence is never silently served, and one compromised host does not expose a document.

Benefit
Every step has a named actor and a record, which supports chain-of-custody review.

leet

RESEARCH AND REFERENCES

SMART INDIA HACKATHON 2026

Details / links of the reference and research work

CRYPTOGRAPHIC STANDARDS

NIST SP 800-38D AES-GCM mode, IV construction & tag length — our per-chunk cipher.

RFC 5869 — HKDF Extract-and-expand KDF; basis of our per-chunk keys.

RFC 8032 — Ed25519 Deterministic EdDSA; no per-signature nonce to reuse.

RFC 6238 — TOTP Time-based one-time passwords for the second factor.

NIST SP 800-57 Pt.1 r5 Key-management lifecycle — gen, storage, rotation, destruction.

NIST SP 800-88 r1 Media sanitization — basis for key & derived-data destruction.

SECURITY ENGINEERING

OWASP ASVS 4.0 Verification checklist our access-control & crypto-storage map to.

OWASP Top 10 (2021) Broken access control & crypto failures drove the 404-not-403 rule.

NIST SP 800-92 Log-management guidance behind the audit schema & retention.

Saltzer & Schroeder (1975) Least privilege & complete mediation — auth re-checked per request.

TLS 1.3 (RFC 8446) All transport over HTTPS in deployment — confidentiality in transit.

TECHNOLOGY & PRIOR ART

pyca/cryptography AESGCM, HKDF, Ed25519 — audited, no custom crypto.

PostgreSQL 16 Full-text search, GIN indexes, xact advisory locks.

Tesseract + Indic data Offline OCR: Hindi, Tamil, Telugu, Bengali, Gujarati.

MinIO · HashiCorp Vault Studied as production swap-ins behind our interfaces.

Ollama · sentence-transformers Studied for the future on-prem AI layer.

OUR OWN DESIGN RECORD

- **Eleven feature plans** plus architecture, security, API and edge-case docs.
- **Spec-first** every crypto & access-control decision written down and threat-modelled before code.
- **Terminology discipline** "tamper-evident" not "immutable"; "least-privilege" not "zero-trust".

WHAT THE READING CHANGED

- **SP 800-38D →** per-chunk HKDF keys instead of one key per file, so an IV cannot repeat under a key.
- **OWASP ASVS →** 404 instead of 403 on case-scoped resources, so existence is never confirmed.
- **NIST SP 800-92 →** audit events carry actor, action, case, document and result — not just a message.

FUTURE SCOPE — AI (READ-ONLY)

- **Context retrieval** semantic search over a read-only derived index, filtered to permitted cases.
- **On-prem summarisation** a local model drafts summaries; evidence never leaves the network.
- **Strict boundary** the AI layer reads a derived copy and can never modify original evidence.